



Module A – Cybersecurity Fundamentals

A2 – Systems Thinking & Risk

Silvia Sisinni

silvia.sisinni@polito.it



**Politecnico
di Torino**

Department of Control and
Computer Engineering



TORSEC

Computer and Network Security Group



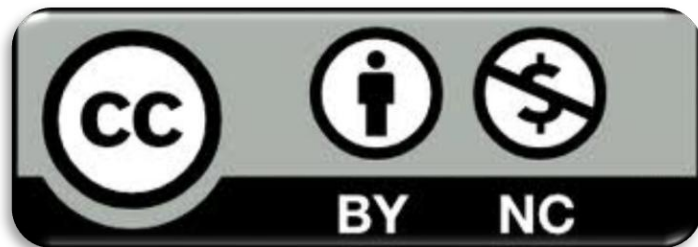
Acknowledgments

This lecture deck *adapts* and *reorganizes* selected teaching material originally developed by Nicolò Maunero (CINI / Cybersecurity National Lab). Portions of the content are reused under the Creative Commons BY-NC license (see license slide). All modifications, additions, re-organization, and any errors are the responsibility of the course instructor.

License & Disclaimer

License Information

This presentation is licensed under the
Creative Commons BY-NC License



To view a copy of the license, visit:

<http://creativecommons.org/licenses/by-nc/3.0/legalcode>

Disclaimer

- We disclaim any warranties or representations as to the accuracy or completeness of this material.
- Materials are provided “as is” without warranty of any kind, either express or implied, including without limitation, warranties of merchantability, fitness for a particular purpose, and non-infringement.
- Under no circumstances shall we be liable for any loss, damage, liability or expense incurred or suffered which is claimed to have resulted from use of this material.
- This material is used and adapted within the course “**Cybersecurity and National Defense**”.



Learning goals

Introducing the concept of

- *Danger*
- *Threat*
- *Asset*
- *Risk*
- *Safety*
- *Security*
- *Dependability*



The concept of Security

In the following, we will introduce the concept of *Security* using different definitions

- different points of view with consequent different practical implications

Remark for Italian attendees:

- the Italian word *Sicurezza* has a broader meaning and includes, as we shall see, several English terms



Security



- *The state of being free from **dangers** or **threats**.*



Danger



- *Intrinsic property or quality accountable to a particular factor (work environment, material, equipment, method, or process) having the potential to generate a harmful event.*
- Example: a high-voltage cabinet is a “danger” regardless of who interacts with it.
- Danger is a property that exists **even in the absence of malicious actors.**



Danger



- *The possibility of suffering harm or injury.*



Threat



- *A statement of an intention to inflict pain, injury, damage, or other hostile action on someone in retribution for something done or not done.*
- Threat introduces **intention** (a hostile agent), unlike danger.



Threat



- *Any circumstance or event with the potential to adversely impact organizational **operations** and **assets**, individuals, other organizations, or the **Nation** through an **information system** via unauthorized access, destruction, disclosure, or modification of information, and/or denial of service.*
- This definition bridges general threats to cyber threats.



Remark

- The nature and peculiarities of the concepts of *danger* and *threat* strongly depend on the target context and application domain.
- For example, consider a **satellite navigation system** (e.g., GPS receiver)
 - In a **civilian context**, relevant threats could include
 - Location privacy violations
 - Manipulation of navigation data
 - In a **military context**, threats to be considered could be
 - Satellite signal spoofing by an adversary
 - Strategic denial of navigation signals



Security



- *The freedom from those conditions that can cause **loss of assets with unacceptable consequences.***

[“Systems security engineering: Considerations for a multidisciplinary approach in the engineering of trustworthy secure systems,”
NIST, Tech. Rep. NIST.SP.800-160 Volume 1, Nov. 2016:
<https://doi.org/10.6028/NIST.SP.800-160v1>]



Practical implications

- Security requires an asset view: no assets → no meaningful security discussion
 - assets define consequences
 - consequences define risk acceptance

- It's thus imperative that the specific scope of security must be clearly defined by stakeholders in terms of:
 - *assets* to which security applies
 - *consequences* against which security is assessed



Asset

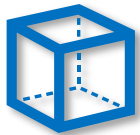


- Any item of **value** owned by an organization that can be **monetized**.



Asset types

- An asset may be:
 - *tangible* (e.g., a physical item such as hardware, computing platform, network device, technology component)
 - *intangible* (e.g., data, information, software, trademark, copyright, intellectual property, image, reputation).
- Intangible assets are often the primary target of cyberattacks.



Impacts of asset loss

- The loss of an asset always has an *impact*, the evaluation of which must be done by analyzing, for that specific asset:

Value

Criticality

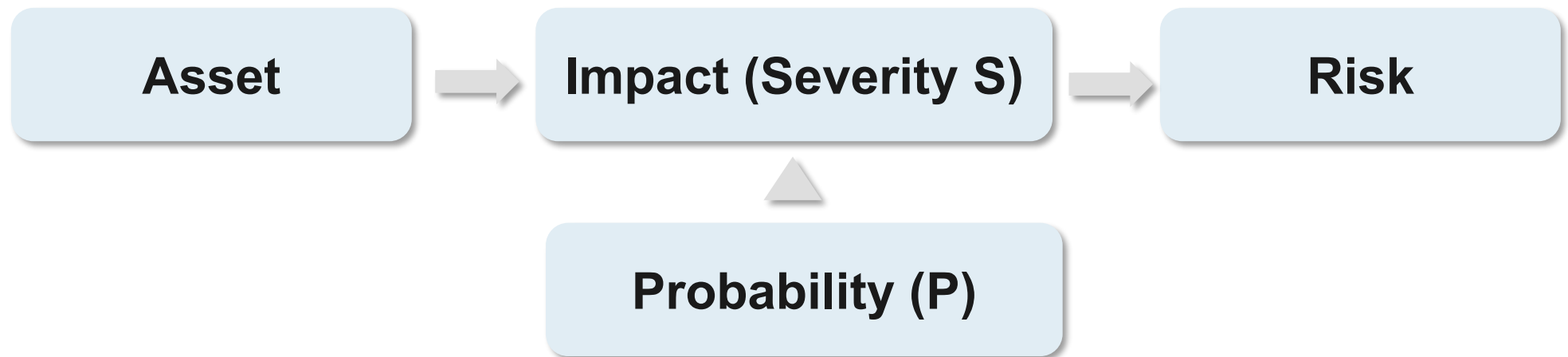
Irreplaceability

Mission Role

- These dimensions define how severe a loss would be
- Impact analysis turns “asset” into “decision priority”



From Assets to Risk





Risk



- *The possibility that human actions or events lead to consequences that have an impact on **what humans value**.*

[O. Renn, “*The role of risk perception for risk management*,” Reliability Engineering & System Safety, vol. 59, no. 1, pp. 49 – 62, 1998,
<http://www.sciencedirect.com/science/article/pii/S0951832097001191>]



Risk



- **Probability (P)** of reaching the potential level of **Harm (S)** under the conditions of use or exposure to a given factor or agent or their combination.

[Art. 2 del TU]



Risk



- *Set of the possibility of an event and its consequences on objectives.*

[UNI 11230 – Risk management]



Risk



- Combination of the **probability** of occurrence of an injury and the **severity** of that injury.

[UNI EN ISO 12100-1]



Risk



- Combination of the **probability** and **consequence** of the occurrence of a specific hazardous event.

[OHSAS 18001, 3.4]



The Notion of Risk

$$\text{Risk } R = S \times P$$

where:

- S = Severity of the impact
- P = Probability of occurrence

The NIST definition

≈ Probability (P)

≈ Severity (S)

$$\text{Risk} = \text{Likelihood} \times \text{Impact}$$

[NIST SP 800-30]

IMPACT	High	Medium	High	High
	Medium	Low	Medium	High
	Low	Low	Low	Medium
		Low	Medium	High
		LIKELIHOOD		



Cyber Risk



- Possibility of **damage** (financial loss, service interruption, or reputational damage) suffered by an organization as a result of a **malfunction** in its **information systems**.



Cyber Risk Examples

Example 1 -- Healthcare service

- **Asset:** clinical data and service availability
- **Threat:** ransomware attack
- **Impact:** service disruption, patient safety risk
- **Cyber risk:** unacceptable disruption on essential healthcare services

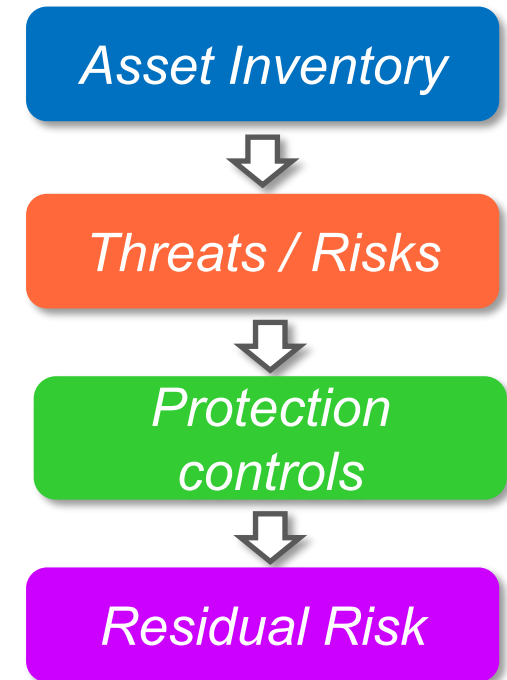
Example 2 -- University information system

- **Asset:** personal data and academic records
- **Threat:** unauthorized access / data breach
- **Impact:** privacy violations, reputational damage
- **Cyber risk:** loss of trust and regulatory consequences

Practical implications

This is the operational loop of risk-based security management:

1. Prepare a detailed **asset inventory**
2. For each asset:
 - **analyze** the possible **threats**: these are the risks that must be considered
 - **prepare** the appropriate **protections** and the needed **countermeasures**
 - **evaluate** (and possibly insure) the **residual risks**



Cyber Risk -- Insurance

- Similarly to what happens for other risks, it is today possible to sign *insurance policies* for the coverage of the residual Cyber Risks.

CAVEAT 2

If the attack is carried out by a state-related entity, insurance companies consider it an act of war and do not reimburse !!!

CAVEAT 1

Insurance covers residual risk, not lack of controls





Cyber Risk -- Implications

The Keynote Speech of Prof. Luciano FLORIDI at the ITASEC21 conference on the implications of risk analysis can be downloaded from:

- <https://2021.itasec.it/scientific-technical/keynote-speech-luciano-floridi/>



Cyber Risk -- Management

- National agencies provide reference methods to standardize risk treatment.
- The Agency for Digital Italy (AgID) and the National Cybersecurity Authority (ACN) make available a tool for assessing and treating cyber risk, now accessible at:
<https://rischiocyber.acn.gov.it/cyber/index.html>

ACN - Agenzia per la Cybersicurezza Nazionale

Entra con SPID



CYBER RISK MANAGEMENT

Tool di valutazione e trattamento del rischio cyber

[Home](#)

[Strategia](#)

[Metodologia e strumenti](#)

[Come partecipare](#)

CYBERSECURITY: DALLA CONSAPEVOLEZZA ALLA GESTIONE DEL RISCHIO



The Italian Cyber Risk Management Tool

The tool allows organizations to:

- carry out cyber risk assessment activities
- define and document appropriate risk treatment plans
- monitor over time the initiatives undertaken to reduce risk levels.

The tool is based on:

- the principles and guidelines defined by ISO 31000 “Risk management -- Principles and guidelines” (Italian version: UNI ISO 31000 “Gestione del rischio”)
- the Information Risk Assessment Methodology 2 (IRAM2), developed by the Information Security Forum (ISF)

[<http://store.uni.com/catalogo/uni-iso-31000-2018>]

[<https://www.securityforum.org/solutions-and-insights/information-risk-assessment-methodology-iram2>]





Protecting what

- People
 - Environment
 - Objects
 - Computers
 - Information
 - Cyberspace
- SAFETY***



Safety



- *Property of a system that reflects the system's ability to operate, normally or abnormally, without danger of causing **human** injury or death and without damage to the system's **environment**.*



Safety



The probability that a system:

- *will either perform its function correctly*
- *or will discontinue its function in a manner that:*
 - *does not disrupt the operation of other systems*
 - *or does not compromise the safety of any people associated with the system.*



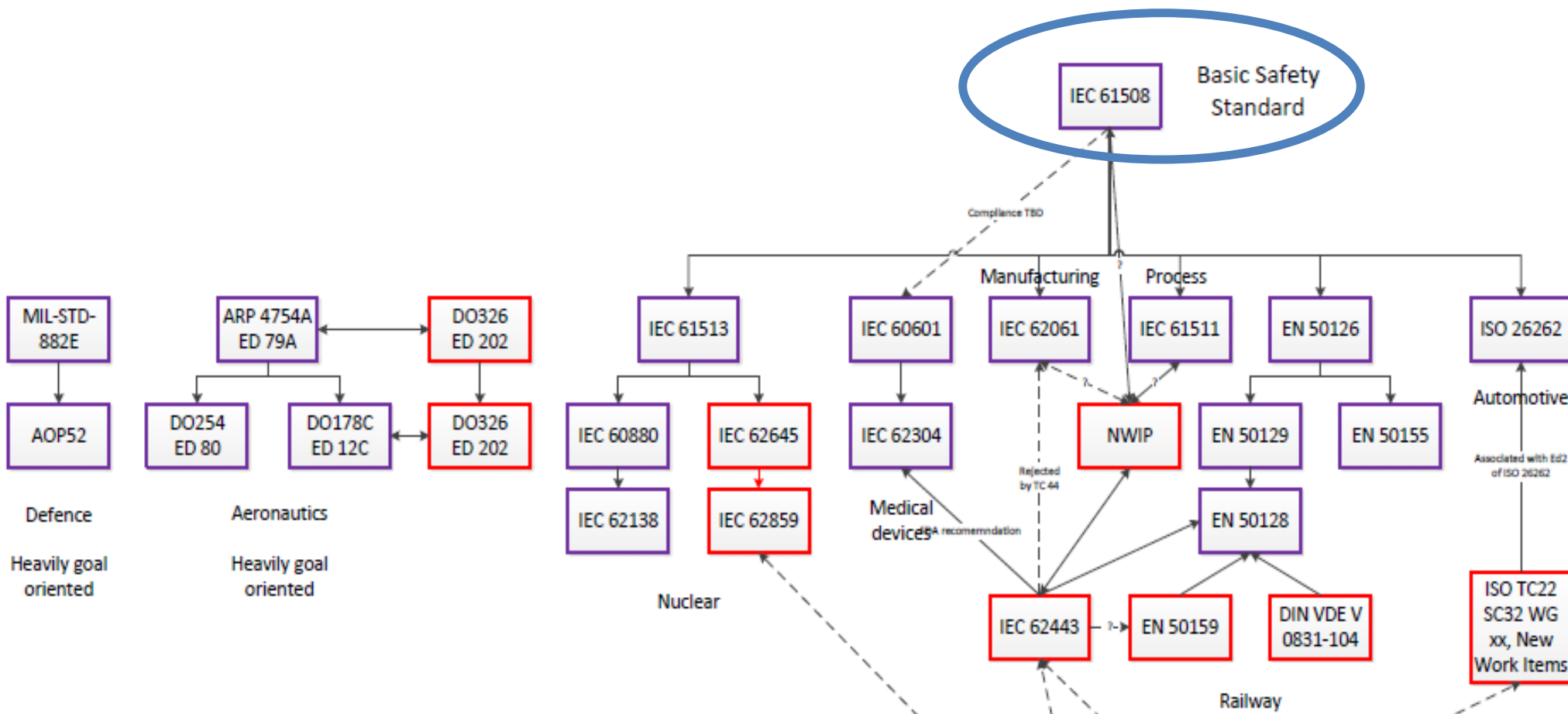
Safe systems may fail, but they must fail safely.



Safety Protection and Standards

- *Safety Critical Systems* are governed by an extensive set of strict international standards.
- Standards encode the **best known practices** and the **state of the art**.
- Standard compliance demonstrates that **everything reasonably possible has been done**:
 - even if incidents occur, compliance provides **technical and legal protection**.
- **Lack of compliance in safety-critical domains is a serious engineering fault.**

Safety Standards





Protecting what

- People
- Environment
- Objects
- **Computers**
- Information
- Cyberspace

SECURITY



Computer Security



- *Deals with the prevention and detection of **unauthorized** actions by users of a computer system.*



Computer Security

- *Authorization* is the cornerstone of the definition.
- Requires the adoption of proper *security policies*, stating *who* (or *what*) is authorized to perform a given set actions (*which* and *when*).
- **Security policy** = *the rule set that defines what is allowed (who/what/which/when).*
- *For example, in a university system:*
 - professors can modify the grades of students in their own courses
 - students can only view their own grades but cannot modify them



Computer Security

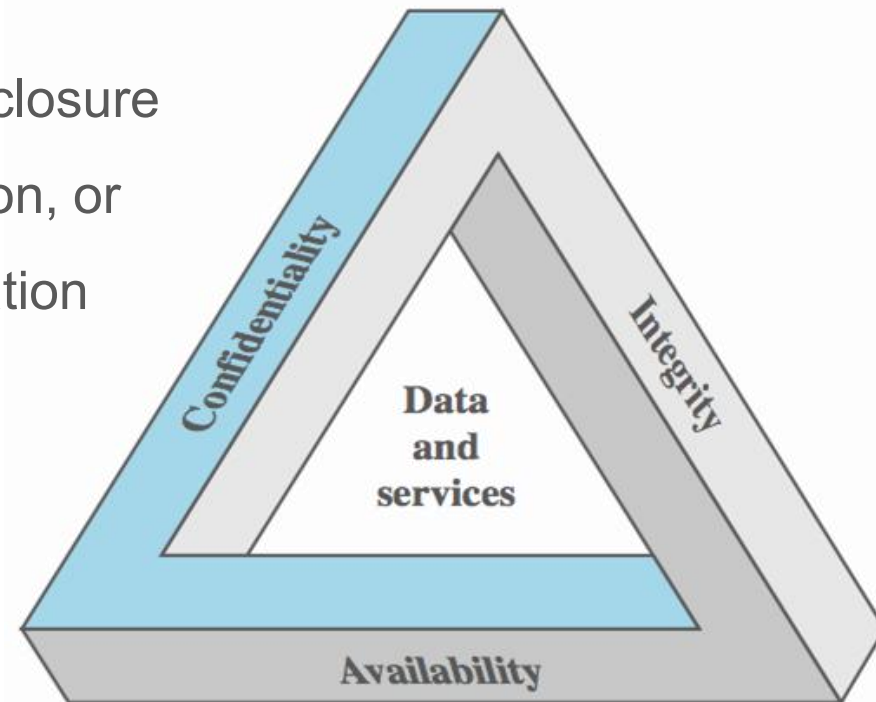


- Measures and controls that ensure *confidentiality*, *integrity*, and *availability* of information system assets including hardware, software, firmware, and information being processed, stored, and communicated.

[The NIST Internal/Interagency Report NISTIR 7298
- Glossary of Key Information Security Terms, May 2013
(NIST = U.S. National Institute of Standards and Technology)]

The CIA triad

- *Confidentiality, Integrity, Availability* are considered the **security pillars** and they form what is usually referred to as the *CIA triad*.
- **Confidentiality**: prevent unauthorized disclosure
- **Integrity**: prevent unauthorized modification, or being able to detect unauthorized modification
- **Availability**: ensure timely access to services/data



They will be deeply analyzed in
the lecture:

A3 – Core Security Concepts



The Italian version - *La triade RID*

The Italian AgID defines the *CIA Triad* $\leftrightarrow$ *RID*:

- *R*iservatezza
- *I*ntegrità
- *D*isponibilità

RID is a linguistic mapping of CIA used in Italian public-sector frameworks.



Computer security – Modalities

- A system can be compromised physically or logically, both are security-relevant.
- Protection requires:
 - *Physical Security*: prevents unauthorized physical interaction with systems.
 - *Logical Security*: prevents unauthorized logical actions on systems and data.



Physical vs Logical Security

Physical Security

- **Access control**
 - access to Buildings
 - offices and desks
- **Environmental protection**
 - fire protection system
 - protection against natural events
- **Infrastructure continuity**
 - electrical continuity
- ...

Logical Security

- **Access and perimeter**
 - perimeter protection
- **System protection**
 - endpoint / server protection
- **Operational continuity**
 - Business Continuity Plan (BCP)
 - Backup & Disaster Recovery
 - Primary / backup links
- ...

Protecting what

- People
- Environment
- Objects
- Computers
- **Information**
- Cyberspace

SECURITY

Covered in lecture:
A3 – Core Security Concepts



Protecting what



- People
- Environment
- Objects
- Computers
- Information
- Cyberspace

CYBERSECURITY



Cybersecurity

- Cybersecurity deals with intentional, intelligent, and adaptive **threats acting through cyberspace.**
- What makes **cybersecurity different** is the **environment in which these threats operate.**
- In cyberspace:
 - attacks can be executed **remotely**,
 - they can spread **very quickly across interconnected systems**,
 - and a single vulnerability may affect **thousands or millions of systems simultaneously.**



The concept of *Failure*

- In general, *failure* is defined as the impossibility to meet a specific requirement, objective, or performance measure.
- Specifically, a *failure* is usually defined in terms of:
 - behaviour exhibited by the system
 - interactions between the elements that compose it
 - produced results
- Example: an infusion pump delivers the wrong dosage due to a sensor fault.

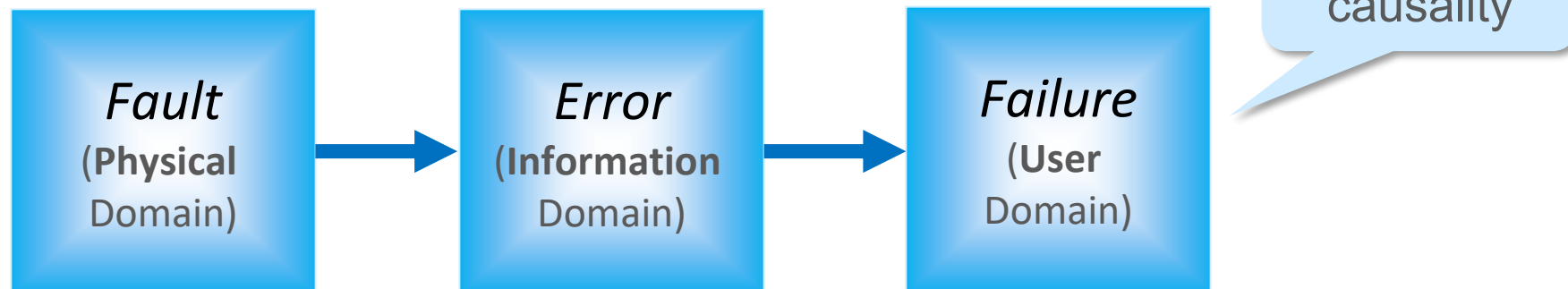


Threat Chain – Different perceptions

- The so-called **threat chain** describes how failures emerge (not how attacks are executed), i.e., the set of steps that leads to failures.
- The *threat chain* is perceived differently within different communities.
- In the sequel, we briefly analyze how the *threat chain* is perceived by:
 - the “Safety community”
 - the “Software community”
 - the “Security community”

The “Safety community”

It usually refers to the so called *3-universe model* to outline the *threat chain* that can lead to a failure:



[A. Avižienis, J.-C. Laprie, B. Randell, C. Landwehr:
“Basic Concepts and Taxonomy of Dependable and Secure Computing”,
IEEE TDSC, 1 (1), pp. 11-33, Jan-Mar 2004]



Threat Chain in Safety: example

- **Braking system of a car equipped with ABS (Anti-lock Braking System)**
- **Fault (Physical Domain):** a wheel speed sensor becomes damaged or disconnected
- **Error (Information Domain):** incorrect measurements of the wheel speed
- **Failure (User Domain):** the ABS controller applies the wrong braking logic => the user experiences an unsafe braking



3-universe threat model

- If, during the design phase, appropriate ***tolerance mechanisms*** have not been foreseen and introduced in the system, a ***fault*** may lead to an ***error*** which, in turn, may lead to a ***failure***.



The “Software community”

It usually resort to other definitions:

- **Error**: a human action that produces an incorrect result.
- **Bug**: an error or a fault that causes a failure (used informally in place of fault).
- **Fault**: an incorrect step, process, or data definition in a computer program.
- **Failure**: the inability of software to perform its required functions within specified performance requirements. A failure occurs **at runtime**, when the system executes the faulty code.

[IEEE Standard Glossary of Software Engineering Terminology]

The “Security community”

It usually refers to the following *threat chain*:



- **Weakness**: a flaw or a limitation in the design or in the implementation of a system.
- **Vulnerability**: when an attacker realize that a weakness can be exploited, it becomes a vulnerability.
- **Attack**: a concrete exploitation of a vulnerability.



Threat Chain in security: example

- Let's consider a **web application** with a login system to authenticate users.
- **Weakness**: the web application does not properly validate user input in the login form.
- **Vulnerability**: the attacker discovers that the login form allows SQL injection
- **Attack**: the attacker injects a malicious query in order to bypass authentication and logs in the system



Comparing Threat Chains

Community	Cause	Chain
Safety	Accidental	Fault → Error → Failure
Software	Human error	Error → Bug / Fault → Failure
Security	Adversary	Weakness → Vulnerability → Attack



Safety vs. Security

In addition to the previous considerations, we will compare safety and security based on the following aspects:

- **Conflicting requirements**
- Threats: Accidentality vs Intentionality
- Threats: Cardinality
- Failure prevention
- The role of standards

Door opening mechanism

Safety Requirement

Doors shall open when car is flipped.

Solution

Install pressure sensor at the roof of the car.

Solution has serious security consequences

Unauthorized entry by jumping on the car.



A system can be safe and insecure at the same time.



The common answer



- The answer **MUST** necessarily be just one:

(Safety & Security)-by-Design

- Security cannot be retrofitted once systems are deployed.



Safety vs. Security

In addition to the previous considerations, we will compare safety and security based on the following aspects:

- Conflicting requirements
- Threats: Accidentality vs Intentionality
- Threats: Cardinality
- Failure prevention
- The role of standards



Threats: *Accidentality* vs *Intentionality*

Safety

The threat is always an accidental event that can be:

- *Endogenous* (e.g., component failure)
- *Exogenous* (e.g., atmospheric event, or electromagnetic noise)
- *Human*, but unintentional (e.g., error in design, manufacturing, testing)

Security

The threat is usually carried intentionally by a malicious agent (human or system).



Safety vs. Security

In addition to the previous considerations, we will compare safety and security based on the following aspects:

- Conflicting requirements
- Threats: Accidentality vs Intentionality
- Threats: Cardinality
- Failure prevention
- The role of standards



Threats: *Cardinality*

Safety

- Failures arise from **limited combinations of accidental events**
- Faults may exist in many systems, but **manifest sporadically**
- Only a small number of systems experience the failure at a given time

Security

- Modern systems often share common software components
 - a single vulnerability may allow attackers to compromise **thousands or millions of systems very quickly**
- Attackers can exploit them simultaneously at large scale



Safety vs. Security

In addition to the previous considerations, we will compare safety and security based on the following aspects:

- Conflicting requirements
- Threats: Accidentality vs Intentionality
- Threats: Cardinality
- Failure prevention
- The role of standards



Failure prevention

- Different solutions are adopted depending on the objectives to be pursued:
 - Safety engineering objective: preventing failures caused by **accidental faults**
 - Security engineering: preventing failures caused by **malicious exploitation of vulnerabilities**



Failure prevention -- Safety

Solution

- Architectures that can tolerate the presence of faults and/or errors (*Fault-Tolerant Architecture*), usually exploiting *redundancy*:
 - Time Redundancy
 - Information Redundancy
 - Functional Redundancy
 - Structural Redundancy

Approach

- A **same operation** is performed **several times** and the results are compared as they are obtained:
 - If the results differ, the system detects that something went wrong.
- Example: **spacecraft and satellite onboard computers**
 - Radiations can cause transient faults
 - Single-event upsets



Failure prevention -- Safety

Solution

- Architectures that can tolerate the presence of faults and/or errors (*Fault-Tolerant Architecture*), usually exploiting *redundancy*:
 - Time Redundancy
 - Information Redundancy
 - Functional Redundancy
 - Structural Redundancy

Approach

- Extra bits added to the data
- Use of *Error Detection And Correction* (EDAC) codes.
- The code to be used is selected based on the type and number of errors that are to be detected and corrected.
- Widely used in communication systems, storage devices, and spacecraft systems.



Failure prevention -- Safety

Solution

- Architectures that can tolerate the presence of faults and/or errors (*Fault-Tolerant Architecture*), usually exploiting *redundancy*:
 - Time Redundancy
 - Information Redundancy
 - **Functional Redundancy**
 - Structural Redundancy

Approach

- The **same system function** is implemented using **different algorithms, models, or components**.
- Results are compared or used as **backup solutions** if one implementation fails.
- Diversity reduces the probability that **the same fault affects all implementations simultaneously**



Failure prevention -- Safety

Solution

- Architectures that can tolerate the presence of faults and/or errors (*Fault-Tolerant Architecture*), usually exploiting *redundancy*:
 - Time Redundancy
 - Information Redundancy
 - Functional Redundancy
 - **Structural Redundancy**

Approach

- Use **multiple identical hardware or software modules** executing the same function in parallel.
- Outputs are combined through a **voting mechanism** to determine the correct result.
- Typical architecture: *N-Modular Redundancy* (NMR)
 - Example: **Triple Modular Redundancy (TMR)**



Failure prevention -- Security

General Solution

- Architectures that remain secure **even when vulnerabilities exist** (*Vulnerability-Tolerant Architectures*).

Approaches

- Defense in depth
- Isolation / sandboxing
- Least privilege
- Monitoring and intrusion detection
- Security Objectives (**CIA Triad**)
 - **Confidentiality** → encryption, access control
 - **Integrity** → hashes, digital signatures, message authentication
 - **Availability** → redundancy, replication, resilient architectures



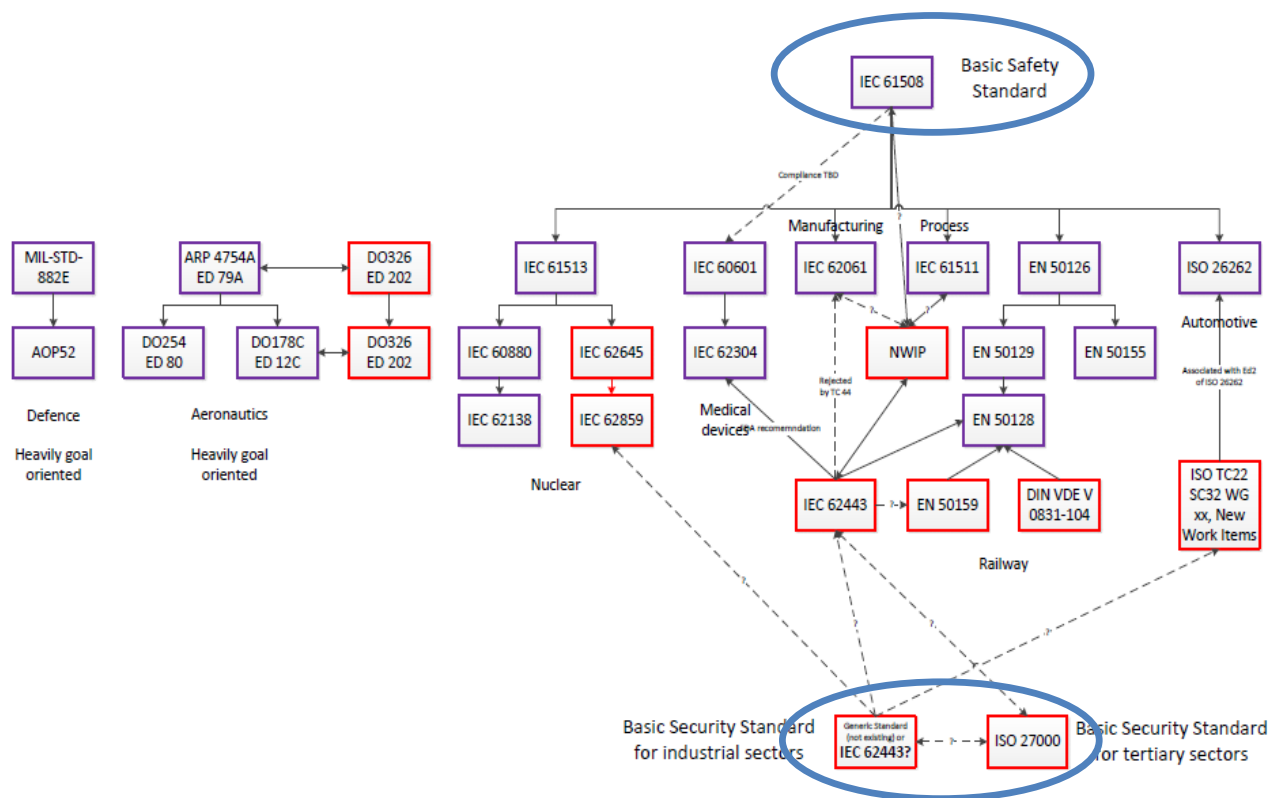
Safety vs. Security

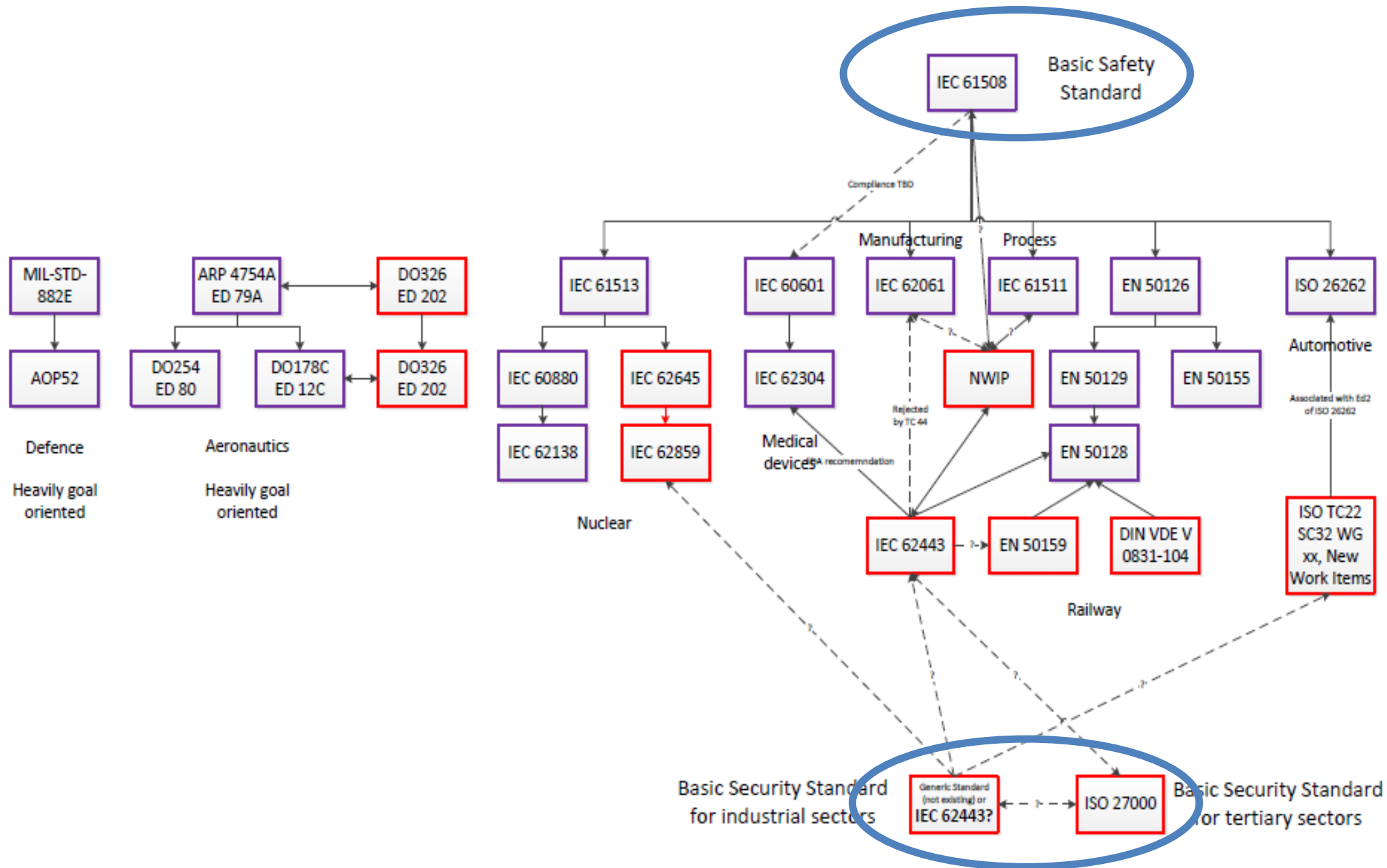
In addition to the previous considerations, we will analyze the following aspects:

- Conflicting requirements
- Threats: Accidentality vs Intentionality
- Threats: Cardinality
- Failure prevention
- The role of standards

The role of Standards

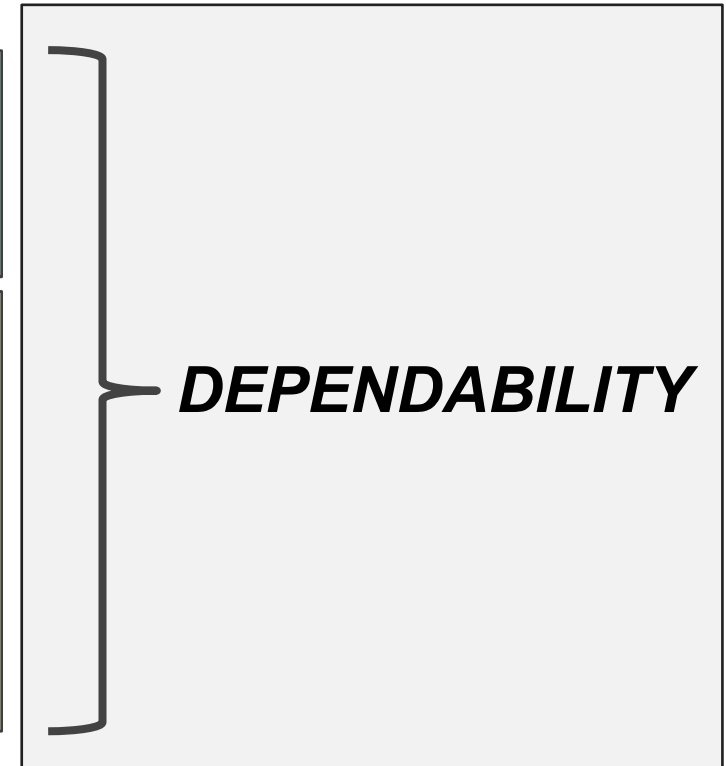
- A significant convergence of standards has already been achieved...





Protecting what

- People
 - Environment
- SAFETY***
- Objects
 - Computers
 - Information
 - Cyberspace
- SECURITY***





Dependability



- *Property of a system that allows reliance to be placed justifiably on service it delivers.*



Dependability Elements

Dependability can be broken down into three elements:

- **Attributes:** the properties that characterize a dependable system.
- **Threats:** the events or conditions that can affect the dependability of a system.
- **Means:** mechanisms and techniques to increase a system's dependability.



Dependability Attributes

- Set of properties that a dependable system should provide.
 - Properties that evaluate the **quality of the service provided**:
 - *Reliability*: the system performs its intended function consistently over time
 - *Safety*: the system does not cause harm.
 - *Security*: ensures protection against malicious actions.
 - *Confidentiality*
 - *Integrity*
 - *Availability*
 - *Maintainability*: the ability to repair and restore the system efficiently when problems occur
- [A. Avižienis, J.-C. Laprie, B. Randell, C. Landwehr: “Basic Concepts and Taxonomy of Dependable and Secure Computing”, IEEE TDSC, 1 (1), pp. 11-33, Jan-Mar 2004]



Resilience



- *Resilience is the ability of a system to:*
 - *prepare for adverse events*
 - *absorb disruption while maintaining essential functions*
 - *recover within mission-acceptable time*
 - *adapt to evolving threats and conditions*

[Adapted from NIST SP 800-39 and NIST SP 800-160]

- It helps an organisation protect against *cyber risks*, defend against and limit the severity of attacks, and ensure its continued survival despite an attack.



Resilience

ITASEC
ITALIAN CONFERENCE ON CYBERSECURITY
April 7-8, 2021 - Online

Answer 3: resilience (to minimise)

KEYNOTE SPEECH
Luciano FLORIDI
University of Oxford